

Internship Reflection

Client Assessments and Red Team Engagement

Christian Bai | RISCPoint Advisory Group | Old Dominion University

My internship at RISCPoint Advisory Group gave me hands-on experience conducting penetration tests and red team assessments for real clients. Working as a Junior Penetration Tester, I completed three major engagements that progressively increased in complexity. Each project taught me different aspects of offensive security, from basic web application testing to sophisticated adversary simulation using the MITRE ATT&CK framework. The experience connected my academic background in criminology, cybersecurity, and law in ways I did not fully anticipate.

The first engagement was a penetration test. I tested a web application with multiple user roles, looking for vulnerabilities in authentication, authorization, session management, and application logic. What struck me most was discovering how many different ways seemingly simple features can be insecure. The logout function, for example, appeared to work correctly from a user perspective. You clicked logout and were returned to the login screen. However, when I tested whether the session was actually invalidated on the server side, I found it was not. The old session token remained valid, meaning anyone who captured it could continue using the account even after logout. This taught me that security testing requires looking beyond surface behavior to understand what is actually happening at the protocol level.

I also discovered vulnerabilities I had only read about in textbooks. The file upload feature had inadequate validation, allowing me to upload files the application should have rejected. While I did not exploit this to achieve code execution due to time constraints, the finding demonstrated how input validation failures create risk. Another significant discovery was that the application used MD5 for password hashing. I knew from my cryptography coursework that MD5 is cryptographically broken, but seeing it in production made the theoretical risk concrete. If an attacker obtained the password database, they could crack those hashes much faster than if a modern algorithm like bcrypt had been used.

The most unexpected findings came from GraphQL testing. I had minimal exposure to GraphQL before this engagement. When I enabled introspection queries, the API returned its complete schema, revealing all queries, mutations, and data types. Additionally, the GraphQL development console was accessible in production. These findings highlighted how development tools left enabled in

production create information disclosure risks. An attacker could use this schema information to craft more targeted attacks or discover functionality that was not meant to be public.

Writing the report taught me how to communicate technical findings to non-technical audiences. I had to explain why each vulnerability mattered in business terms, not just technical terms. A session fixation vulnerability was not just a protocol issue. It was a risk that customer accounts could be hijacked. Using CVSS scoring helped me quantify risk objectively, but I learned that scoring alone was not enough. I needed to consider the specific context of how the client used the application and what data was at risk.

The second engagement presented different challenges. Testing ten distinct user roles meant I needed to understand the intended access control model before I could identify violations. The critical finding was an authorization bypass that allowed lower-privileged users to access administrative functions. I discovered this by intercepting requests in Burp Suite and modifying parameters to reference resources that should have been restricted. The application checked authentication but not authorization, meaning it verified you were logged in but not whether you had permission for specific actions. This vulnerability demonstrated why defense in depth matters. The application had multiple security controls, but the missing authorization check undermined them.

I also identified that the client used the OAuth 2.0 implicit flow, which has been deprecated due to security concerns. The implicit flow exposes access tokens in the browser, creating opportunities for token theft. Modern best practices recommend the authorization code flow with PKCE instead. Finding this required understanding OAuth specifications and staying current with evolving security standards. It reinforced that security is not static. What was considered acceptable a few years ago may no longer meet current best practices.

Working with an international client also exposed me to regulatory considerations beyond typical U.S. frameworks. This client operated in Europe and had to comply with GDPR. This meant my recommendations needed to account for data protection requirements, right to erasure, and other European privacy standards. The experience showed me how legal and regulatory context shapes security priorities differently across jurisdictions.

The third engagement was a red team assessment, which was the most challenging and educational project. Unlike penetration tests that aim to find as many vulnerabilities as possible, red teaming simulates a specific adversary trying to achieve defined objectives. My goal was to breach the client's production environment boundary, starting from the position of an external unauthenticated attacker. The engagement followed federal compliance guidelines and used the MITRE ATT&CK framework to structure the attack chain.

I began with extensive reconnaissance, gathering information about the organization's digital footprint. This phase taught me to think like an attacker conducting target research. I enumerated their domains, identified exposed services, discovered employee information through public sources, and mapped their external infrastructure. The amount of information available publicly was surprising. Through search engines, public repositories, and DNS enumeration, I built a detailed picture of potential attack vectors without touching their systems directly.

The social engineering component involved crafting spear phishing campaigns against employees who had access to systems within the production boundary. I created two campaigns with different sophistication levels to test detection capabilities. Designing these campaigns required understanding human psychology and what makes messages believable. I researched the company culture, mimicked internal communication patterns, and crafted pretexts that aligned with plausible business scenarios. This was where my criminology coursework became directly relevant. Rational Choice Theory helped me understand how attackers evaluate the cost-benefit of different social engineering approaches. I had to consider what level of effort would be required versus the likelihood of success and detection.

During vulnerability scanning, I discovered a critical authentication system vulnerability that allowed unauthenticated client registration. This finding demonstrated the importance of keeping authentication systems patched and properly configured. I also identified several information disclosure issues. Exposed monitoring metrics revealed internal system details including service versions, performance data, and infrastructure topology. Framework version disclosure in HTTP headers gave attackers information about potential vulnerabilities. Internal IP addresses leaked through headers provided reconnaissance data about network architecture. Each of these findings individually seemed minor, but collectively they provided an attacker significant intelligence for planning further attacks.

The red team engagement taught me to think strategically about attack paths rather than just identifying individual vulnerabilities. I had to chain findings together, considering how initial access could lead to persistence, how persistence enabled lateral movement, and how lateral movement could achieve the final objective of breaching the production boundary. This required understanding the relationship between vulnerabilities and thinking several steps ahead about how an adversary would progress through the attack chain.

Working with the MITRE ATT&CK framework provided structure to the chaos of adversary simulation. Each technique I employed mapped to documented tactics used by real threat actors. This framework helped me communicate what I was doing in a standardized language that security teams

understand. It also ensured I was testing relevant attack vectors that organizations actually face rather than theoretical or outdated techniques.

One challenge I faced was learning to prioritize. In penetration testing, you cannot test everything. Time constraints mean you must focus on the most likely and highest-impact attack vectors. Early in the internship, I would sometimes spend too much time on low-probability vulnerabilities while missing obvious issues elsewhere. I learned to develop intuition about where vulnerabilities typically hide and which findings warranted deeper investigation versus which were likely false positives or low impact.

Documentation proved more challenging than I expected. I had to maintain detailed notes during testing because information I thought I would remember often became fuzzy later when writing reports. Screenshots, command outputs, and timestamps became essential for proving findings and reconstructing what I did. I developed a systematic note-taking process that captured enough detail to write comprehensive reports without slowing down my testing too much.

The internship reinforced connections between my academic disciplines that were not obvious in the classroom. Criminology provided frameworks for understanding attacker motivation and decision-making. When assessing risk, I considered whether an attack was attractive from a rational choice perspective. Did it offer sufficient reward relative to effort and risk of detection? Routine Activity Theory helped me think about security controls as capable guardians protecting suitable targets from motivated offenders. Legal knowledge helped me navigate authorization boundaries, understand compliance requirements, and appreciate why rules of engagement matter. Technical cybersecurity skills enabled me to actually identify and demonstrate vulnerabilities.

This internship confirmed that my interdisciplinary approach has practical value. The field needs people who understand both the technical aspects of security and the human, organizational, and legal context in which security operates. Moving forward, I plan to pursue advanced certifications like OSCP and continue developing expertise in adversary tactics through the MITRE ATT&CK framework. I also recognize areas where I need growth, particularly in programming for automation, advanced exploitation techniques, and cloud security architectures. The experience showed me that effective cybersecurity requires technical skills, understanding of human behavior, knowledge of legal and regulatory frameworks, and the ability to communicate across all those domains. That holistic perspective is what makes the field engaging and what will guide my continued development.